

REQUEST FOR PROPOSAL & STATEMENT OF WORK

Enterprise Cybersecurity Infrastructure — GovProtect Agency

Client: GovProtect Agency | **Vendor:** ShieldForce Security | **Budget:** \$3,100,000 | **Duration:** 15 months | **Start:** 2026-10-01

1. Project Overview & Goals

GovProtect Agency requires implementation of a zero-trust security architecture covering 12,000 endpoints, a Security Operations Centre (SOC), SIEM/SOAR platform, and privileged access management. All systems must comply with NIST CSF 2.0, FISMA High, and FedRAMP Moderate baselines.

Goals: (1) Achieve FISMA High authorisation within 12 months. (2) MTTD <1h for Tier-1 incidents. (3) MTTR <4h for critical incidents. (4) 100% endpoint coverage in EDR within 6 months. (5) Zero successful phishing credential harvests post-training.

2. Scope of Work & MVP

MVP (Month 1–4): SOC operational with 24/7 monitoring; EDR deployed to 80% of endpoints; SIEM collecting logs from all Tier-1 systems. MVP complete when SOC detects and responds to simulated APT exercise with MTTD <2h.

Out of Scope: Physical security systems; classified network (SIPR) integration; end-user application development.

3. Work Breakdown & Timelines

ID	Work Item	Timeline	Entry Criteria	Definition of Done / Exit Criteria
WI-001	Zero-Trust Architecture Design	Month 1–2	Current-state assessment complete	2. Achieve NIST CSF 2.0 High baseline approved; identity provider integrated; micro-segmentation design approved
WI-002	EDR Deployment (All Endpoints)	Month 2–5	WI-001 done; endpoint inventory complete	100% Windows/Mac/Linux endpoints enrolled; policy tuned (FIPS 140-2)
WI-003	SIEM & Log Management	Month 2–6	Log source inventory complete; data ingestion pipeline live	All Tier-1 log stores connected; retention 12 months hot/24 months cold
WI-004	SOC Operations & Playbooks	Month 3–7	WI-003 live; analysts hired and trained	50+ detection rules active; 30 response playbooks documented
WI-005	PAM & Identity Governance	Month 5–9	WI-001 done; AD/LDAP mapped	All privileged accounts in vault; session recording for admin accounts
WI-006	SOAR Automation	Month 7–11	WI-004 done; SOAR platform deployed	MTTR reduced to <4h for Tier-1 playbooks; 80% of low-severity incidents automated
WI-007	FISMA Authorisation Package	Month 10–14	All controls implemented; POA&MS complete	System Security Plan complete; security assessment complete

4. Legal & Contractual Obligations

4.1 Late Delivery Penalty: 2% of milestone value per week of delay. Maximum cumulative penalty: 20% of total contract value. Delays to FISMA milestones trigger mandatory escalation to Agency CIO within 48 hours.

4.2 Subcontracting: Subcontracting of any security-cleared role is strictly prohibited. Non-cleared roles (e.g., hardware provisioning) may be subcontracted with ISSO written approval. All personnel must undergo agency background checks.

4.3 Indemnity: Vendor indemnifies Client in full against any breach, loss, or regulatory finding arising from Vendor's implementation, including zero-day exploitation of Vendor-deployed tools within 90 days of deployment. Indemnity

unlimited for gross negligence.

4.4 Intellectual Property: All playbooks, detection rules, SOAR workflows, and documentation are works-for-hire and vest in Agency. Vendor may not reuse Agency-specific threat intelligence in any external product.

4.5 Insurance: Cyber Liability $\geq$ \$20M; Professional Indemnity $\geq$ \$10M; Crime/Fidelity Bond $\geq$ \$5M. All policies must have government contractor endorsements.

5. Security Requirements

5.1 SAST: All custom SOAR playbooks and detection rule code undergo continuous SAST scanning. Vendor's internal SDLC must be NIST SP 800-218 (SSDF) compliant. Evidence of SAST pipeline shared monthly.

5.2 VAPT: Monthly automated vulnerability scanning; full red team exercise at Month 6 and Month 12 by an independent government-approved assessor. Red team scope: full kill chain including phishing, exploitation, and lateral movement.

5.3 Penetration Testing: Continuous attack surface management; quarterly web-app pen test; annual ICS/OT-scope assessment. All critical findings must be remediated within 72 hours with Client CISO sign-off.

6. Project Closure

Closure: (1) ATO issued by AO. (2) 100% endpoint EDR coverage maintained 90 days. (3) SOC MTTD <1h demonstrated in red team exercise. (4) All POA&M; items closed. (5) Continuity of Operations (COOP) plan tested. (6) Full knowledge transfer to Agency SOC team. (7) 6-month retainer for incident response support included.